

Voicecon Mobile — Password API Guide

Forgot password (OTP) and change password · Add-on to the Mobile Chat API Guide · v1.0 · 8 Oct 2026

1. Basics

Item	Value
REST base URL (production)	<code>https://api.voicecon.ai/api/v1</code>
Format	JSON request and response. Send <code>Content-Type: application/json</code> .
Auth	Forgot / reset need no token. Change password needs <code>Authorization: Bearer <access_token></code> .
Errors	<code>{"detail": "..."} </code> with a message you can show to the user. Validation errors (422) use a different shape (see section 4).

Screen	Endpoint
Forgot password: enter email	<code>POST /auth/password/forgot</code>
Enter OTP + new password	<code>POST /auth/password/reset</code>
Settings: change password	<code>POST /users/me/change-password</code>

2. Forgot password (OTP)

- 1 The user enters their email, and the app calls `/auth/password/forgot`.
- 2 Voicecon emails them a 6-digit code (valid for 10 minutes).
- 3 The user enters the code and a new password, and the app calls `/auth/password/reset`.
- 4 The response contains tokens, so the user is signed in. Go straight to the home screen.

POST `/auth/password/forgot` — send OTP

Request

```
{ "email": "user@example.com" }
```

Response **200**

```
{
  "message": "If that email has an account, we've sent a reset code to it.",
  "expires_in_minutes": 10,
  "debug_code": null
}
```

- It returns the **same 200 whether or not the email has an account**, so it can't be used to find out which emails are registered. Always move to the OTP screen.

- Ignore `debug_code`. It is always `null` in production.

Resend limits

Rule	Value
Code length / lifetime	6 digits / 10 minutes
Wait between resends	60 seconds
Max codes per email	5 per hour
Over the limit	429 with a <code>Retry-After</code> header (seconds). Use it for the resend countdown.

```
429 { "detail": "A code was just sent. Please wait 42 seconds before requesting another." }
429 { "detail": "Too many codes requested for this email. Please try again in an hour." }
```

POST `/auth/password/reset` — verify OTP + set new password

Request

```
{
  "email": "user@example.com",
  "code": "123456",
  "new_password": "NewStrongPass#1"
}
```

Response **200** (same shape as login)

```
{
  "access_token": "eyJ...",
  "refresh_token": "eyJ...",
  "token_type": "bearer",
  "user": {
    "id": "uuid", "email": "user@example.com", "full_name": "Jane Doe",
    "is_verified": true, "auth_provider": "email", "is_new": false
  }
}
```

There is **no separate "verify OTP" call**. The code is checked in the same request that sets the new password, so collect both on one screen (or keep the code in memory and send it with the password).

Errors — 400 {"detail": "..."}

Message	When
That code is not correct. 3 attempts left.	Wrong code (count goes down)
Too many incorrect attempts. Request a new code and try again.	5 wrong tries
That code has expired. Request a new one.	After 10 minutes
That code is not valid. Request a new one and try again.	No code was issued or it was already used

Other things to know:

- A successful reset signs the account out on every other device.
- It clears any login lockout caused by failed sign-in attempts.
- It marks the email as verified.

3. Change password (logged in)

POST /users/me/change-password

Header: Authorization: Bearer <access_token>

Request

```
{
  "current_password": "OldPass#1",
  "new_password": "NewStrongPass#1"
}
```

Response **204 No Content** (empty body) means it worked.

Important: changing the password signs out **every** session, **including the current one**. After a 204, clear the stored tokens and send the user to the login screen, or call login again with the new password.

Status	Meaning
204	Password changed
400	{"detail": "Current password is incorrect"}
401	Token missing or expired
422	New password breaks a rule (section 4)

`current_password` may be left out **only** for Google / Apple accounts that have never set a password. That is how those users set their first password.

4. Password rules

These apply to `new_password` in both reset and change:

- 8 to 72 characters
- Not a commonly used password (e.g. `password123`)
- Not the same character repeated (`aaaaaaaa`)
- Not a keyboard sequence (`12345678` , `qwertyui`)
- Not only spaces
- For reset, it also can't be the user's own email

A broken rule returns **422**:

```
{
  "error": "ValidationError",
  "message": "Request validation failed",
  "details": [
    { "loc": ["body"], "msg": "Value error, Password must be at least 8 characters.",
      "type": "value_error" }
  ]
}
```

Show `details[0].msg` with the `Value error,` prefix removed.